

Network Information and Security (NIS)

Subject Code :- 22620

Unit II :-

User authentication and access control.

2.1 Identification and Authentication :-

Identification is the act of identifying a particular user often through a username.

Authentication is the proof of this user's identity, which is commonly managed by entering a password.

It is any procedure by which it can test that someone is who they claim they are. This generally contains a username & password, but can involve some other methods of demonstrating identity including smart card, retina scan, fingerprints etc.

* Username and Password :-

Basic Method of identifying any individual in the digital world.

Passwords are generated so that a particular individual can authenticate himself for current information provided.

* Guessing Password :-

There are no. of methods to crack a user's password, but the most prominent one is a password guessing attack.

Basically, it is a process of attempting to gain system's access by trying on all possible passwords.

If the attacker manages to guess the correct one, he has complete access to remote system can manipulate data, and may demand a ransom in exchange for system data.

* Password Attacks :-

Password attack is a common attack used to bypass or exploit authentication of user accounts.

Password attacks involve exploiting a broken authorization vulnerability in the system combined with automatic password attack tools that speed up the guessing and cracking password.

These types of Attacks can be classified into following different attacks.

- 1) Dictionary attack
- 2) Brute force attack
- 3) Key - logger attack
- 4) Man-in-the middle attack.

5) Credential Surfing attack :-

① Dictionary Attack :-

There are a number of most commonly found passwords online in the form of dictionaries. This dictionary consists of a list of passwords leaked in a data breach or commonly used passwords.

Example :-

abc123, 1234567890, password, abcdef etc.

Prevention :-

- 1) Include a combination of upper case, lower case and special symbols into password to make it more secure.
- 2) Make sure the password manager you are using is secure and is not engaged in selling of data.
- 3) Avoid creating weaker password (like password, ab123, etc.) instead create a strong password (like ush!33, snoopdoggyd0k, etc).
- 4) Create a password with atleast 8 character long, which makes it difficult to carryout the attack.

② Brute force attack :-

This method includes trying all possible permutations of passwords until finding the correct one. The time taken depends on complexity of passwords, weaker passwords can be cracked within a couple of minutes while stronger ones may take several hours or days.

Generally, these types of attacks may be detected by the system and account may be locked to prevent unauthorized access due to many failed login accounts attempts, though attacker find ways to bypass detection & successfully crack the password.

Prevention :-

- i) Make stronger passwords
- 2) Create passwords at least 8 ch. long, which makes it difficult to carry brute force attack.
- 3) Regularly change passwords in case they are being compromised.
- 4) Never include personal information like name, date of birth etc.

③ Key - logger attack :-

Key-loggers are malicious software made with the purpose to record all keystrokes of user and report them back to hacker. Mostly, user installs software from unofficial sources believing it to be legitimate, but software installs key-logger without the user knowing it.

This results in all keystrokes being recorded and reported to hacker, in many cases hacker is able to guess password easily.

Prevention :-

- 1) Regularly update your software for security patches.
- 2) Buy antivirus software from a reputed company and have system scan from time to time.
- 3) Make sure you don't plug in unknown media devices like pen-drives.

④ Man-in-the-middle Attack :-

Basically, in these type of attacks the hacker intercepts (or get access to the compromised system) the original connection b/w user and web app/ server and acts as a middle man between the client and server. In this way, hacker has access to information passing between client and server, including passwords.

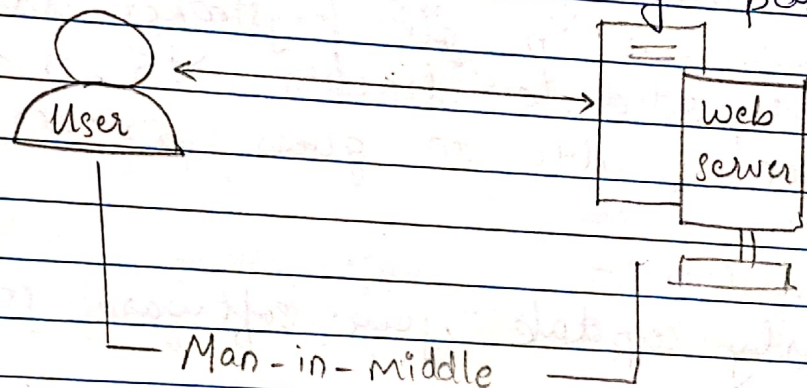


Fig:- Man-in-the-middle Attack.

Prevention :-

- 1) Ensure you have a strong password and two factor authentication turned on.
- 2) Make sure your router is encrypted.
- 3) Avoid using public wifi and use a VPN for proper encryption of traffic.
- 4) Make sure the web application you are using is secure and follows HTTPS protocol.

⑤ Credential Stuffing Attack :-

One day or the other we all know about data breaches of various websites (mostly weak and disrepute). The hacker takes advantage of this.

Generally, some people do not frequently change their passwords, or if they change, it would be quite similar to old ones. For in times of data breaches of various websites the hacker try to find out your record and attempt to gain access to your account by trying different permutations of leaked passwords.

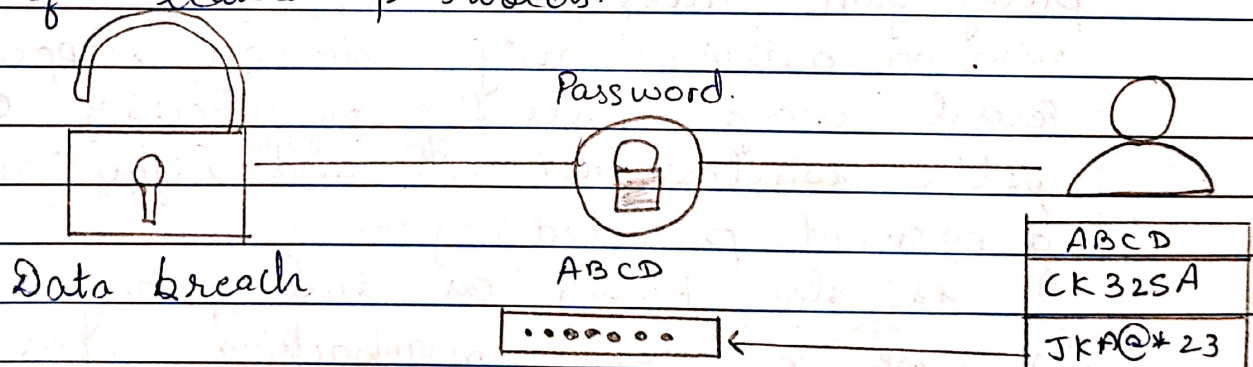


Fig:- Credential stuffing attack.

Prevention :-

- i) Regularly monitor your account for unusual activity.
- 2) Check whether your credentials were ever involved in data breaches.
- 3) Regularly change your passwords in case it

is compromised

- 4) Have a complex password and make sure they aren't similar to older ones.
- 5) Make sure your browser or device doesn't save your password, do it is not leaked in case your device is lost.

* Piggy-backing :-

In the context of computer science and digital communications, "piggybacking" refers to a situation where an unauthorized party gain access to some system in connection with an authorized party. This can happen in several ways, including piggybacking on public wireless network, and piggybacking into a password protected system.

- In case of security, piggybacking refers to when a person along with another person who is authorized to gain entry into a restricted area or pass a certain checkpoint.
- Piggybacking on internet access is the practise of establishing a wireless internet access service without explicit permission or knowledge.

- It is the tactic of closely following a person who has just used an access card or pin to gain physical access to a room or a building.

* Shoulder surfing :-

Shoulder surfing refers to techniques for observations like looking over someone's shoulder, to obtain information. It is commonly used to get pin, password, security codes and similar confidential data.

It is particularly effective in crowded places because it is relatively easy to observe someone as

- They fill a form
- Enter pin at an ATM.
- Use a telephone card or a public telephone
- Enter a password at a public place like cyber cafe.
- Enter a code for a rented locker in a public place.
- Public transport is a particular area of concern.

Shoulder surfing attack can be performed at long distances too with help of visionary aids like binoculars or any such vision enabling devices.

* Prevention :-

- a) Looking for an area of free space where your back is against the wall.
- b) Never give or share your password or any vital information to anyone.
- c) Never open private accounts at public places
- d) Lock your mobile or device when you are not nearby.

* Dumpster diving :-

Dumpster diving is a process of searching trash to obtain useful information about a person, business that can later be used for hacking purpose. This attack mostly targets large organizations or businesses to carry out phishing (mostly) by sending fake emails to victims that appear to have come from a legitimate source.

The information obtained by compromising the confidentiality is used for identity frauds.

• what does a hacker look for?

- a) email address
- b) Phone nos.
- c) passwords
- d) bank details
- e) medical records
- f) important documents.
- g) business secrets
- h) information about software tools, technologies of companies.

* Prevention :-

- a) In case you are no longer using your PC, make sure you discard the data so that it cannot be recovered.
- b) Use of firewalls can prevent suspicious internet users from accessing discarded data.
- c) Paper documents should be discarded permanently.
- d) Companies should lock waste bins and should have a safe disposal policy.

2.2 Biometrics :-

Biometrics can be defined as the most practical means of identifying and authenticating individuals in a reliable and fast way through unique biological characteristics.

Following is a block diagram

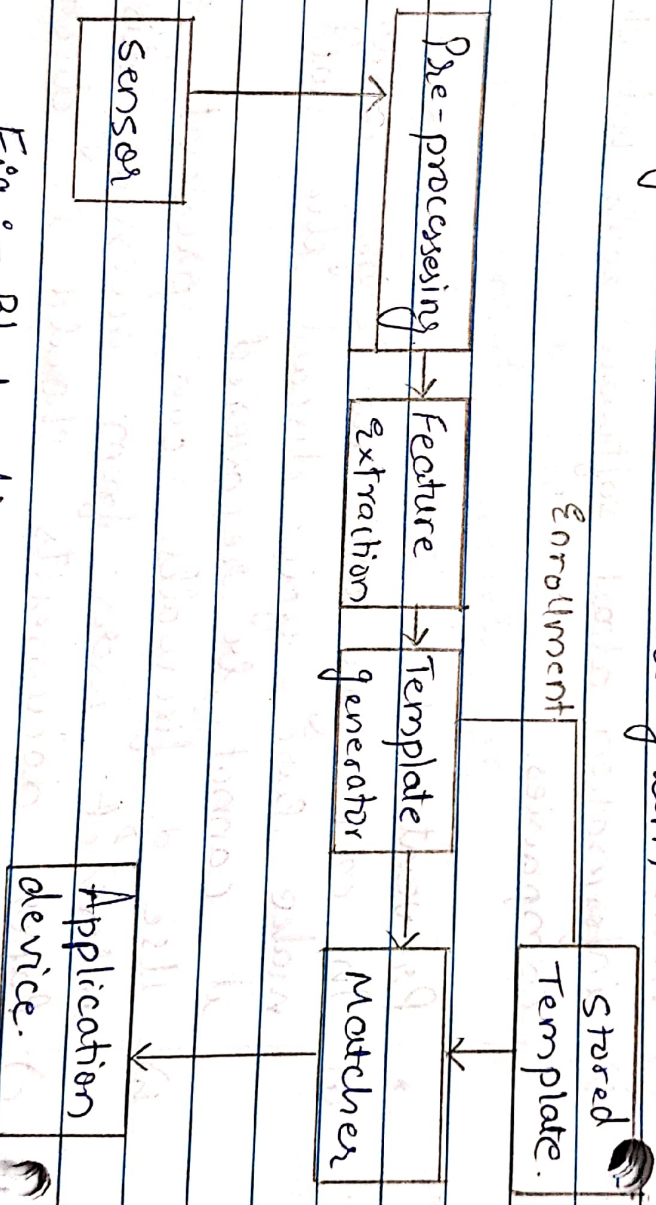


Fig :- Block diagram for Biometric processing.

Biometrics consists of a reader or scanning device, software that converts scanned information into digital form and wherever the data is to be analysed a database that stores the biometric data for comparison with previous records.

- When converting the biometric input the software identifies point of data as match points. The match points are processed using algorithms into a value that can be compared with biometric data scanned when a user tries to gain access.
- Biometric identification system can be grouped based on main physical characteristics that lends itself to biometric identification.

1) Fingerprint

Fingerprint system analyse the location of "minutiae" - the endings and bifurcations of the friction ridges on the pad of your finger. Often additional information, such as no. of ridges between minutiae is also used.

- A no. of methods exists to capture fingerprints: optical capture uses visible light, capacitive sensors use electrical current conducted through the finger, and ultrasound uses high frequency sound waves.
- Contact sensors capture an image of the ridge pattern in contact with sensor, while contactless sensors effectively take an image (2D or 3D).

depending on system) of ridge pattern while finger is held at a distance from sensor.

2) Handprints :-

As in case of fingerprints, everybody has unique ~~fi~~ handprints.

A handprint biometric system scans hand and fingers and data is compared with specimen stored for you in the system. The user is allowed or denied based on the result of this verification.

3) Retina :-

Retinal recognition is the process of scanning a retina and ~~so~~ cross referencing the imaging with data set of unique retinal features. It is one of the most unique biometric identification technique available.

Proper retina imaging can contain upto 400 unique data points for examination. This is in comparison to only about forty unique data points for a fingerprint.

Retinal recognition was first conceived in 1970 but the 1st retinal recognition biometric was not released till 1980.

* Patterns :-

Voice Pattern :-

Voice directly combines biological and behavioural characteristics. The sound an individual makes when speaking is based on physical aspects of the body (mouth, nose, lips, vocal cords and so on) and can be affected by age, emotional state, native language and medical condition. The quality of the recording device and ambient noise also influence recognition rates.

* Signature :-

How a person signs his or her name typically changes over time. It can also be strongly influenced by context, including physical conditions and emotional state of signer. Extensive experience has also shown that signatures are relatively easy to forge. However, signatures have been accepted as a method of recognition for a long time.

* Keystrokes :-

Keystroke dynamics are a biometric trait ~~th~~ some hypothesize may be distinctive to individuals. Indeed there is a long

tradition of recognizing morse code operations by their fists - the distinctive pattern individuals used to create messages.

However keystroke dynamics are strongly affected by context, such as person's emotional state, his or her posture, type of keyboard and so on.

2.3 Access Controls :-

Access control is a usual way of talking about controlling access to a web resource. Access can be granted or denied based on a broad variety of criteria, including network address of the user, time of the day, internet which user is using.

Access control is similar to locking gate at closing time, or only letting person onto ride who are higher than 48 inches tall its controlling entrance by some arbitrary condition which may or may not have anything to do with attributes of specific visitor.

Access control includes :-

- 1) Authentication of user
- 2) Authorization of their privileges
- 3) Auditing to monitor and record user actions.

There are 3 types of access control systems.

- 1) Discretionary access control.
- 2) Mandatory access control
- 3) Role based access control.

⇒ Authentication Mechanism :-

Access is the ability of a subject to interact with object.

- Authentication deals with verifying identity of a subject. It is the ability to specify, control and limit access to host system or application.

Generally there are 3 methods in authentication.

a) Something you know :-

Common method is to provide a username & password. Password should not be shared with anybody else, only you should know your password.

b) Something you have :-

This method involves use of something that only valid user should have like lock & Key

c) Something about you :-

This method involves something that is unique about you like fingerprint, DNA samples etc.

* Authentication and Authorization:-

User authentication is the basis for most types of access control.

The process of verifying an identity claimed by or for a system entity. An authentication process consists of 2 steps:-

- 1) Identification step:- Presenting an identifier to security system. (Identifier should be assigned carefully, because authenticated identities are the basis for other security services, such as access control service.)
- 2) Verification step:- Presenting or generating authentication information that corroborates the binding b/w entity and identifier.

Authorization:-

The granting of a right or permission to a system identity entity to access system resource. This function determines who is trusted for a given purpose.

→ Principle of Authentication:-

The purpose of access control is to limit the actions or operations that a legitimate user of a computer system can perform.

- Principle of least privilege :- It states that if nothing has been specifically assigned for an individual or groups then user should

not be able to access that resource.

- Separation of duties :-

It states that something has been specifically assigned for an individual or group. the user should be able to access that resource only.

- Need to know :-

It states that individual should be given access to specific information that they absolutely require in order to perform their job duties.

→ Access control Matrix :- (ACM)

It provides a simple framework for showing the process. It is a conceptual model that describes access rights of each subject for every resource available.

obj Sub	File1	File2	File3
User 1	owner	Read/w.	Read
User 2	R/w.	owner	Read.
User 3	Read	Approve.	Owner.

Access Control list (ACL) :- Implementation of access controls in a system may vary, but access control list remains common.

* Audit :-

It is an id. independent review and examination of a system record and activity in order to test the adequacy of a system, control to ensure compliance with established policy and operational procedures to detect potential risks, breaches in security and recommend any changes required for the betterment of the system.

* Policies :- DAC, MAC, RBAC.

1) Discretionary Access Control :- (DAC)

- It is also known as Identity based access control (IDBAC)
 - DAC policies are a means of assigning access rights based on rule specified by user.
 - DAC mechanism controls are defined by user's identification with supplied credentials during authentication, such as username & password.
 - DAC policies include file permissions model implemented by nearly all operating systems.
 - DACL determines which users can access objects (system resources) for operations.
- It consists of a list of Access control entities

* Drawbacks of DAC

- 1) It relies on decision by end user to set proper level of security. As a result incorrect permission might be given to an unauthorized subject (user).
- 2) Subject permissions will be inherited by any programs that subject executes.

* Mandatory access Control (MAC) :-

MAC policies are a mandatory layer that cannot be skipped or by passed.

- It is a security model that restricts access to resources based on sensitivity of information and clearance of user.
- MAC policies are used to control access based on mandated regulations determined by central authority.
- They allow you to create more complex rules to fit the needs of your organisation.
- (LBAC) Lattice based access control model is an example for handling complex access controls on interaction b/w any combination of objects (resources, computers, application) and subjects (individuals, groups, organisations)

* Role Based Access control :- (RBAC)

- A user is an entity that accesses resources of the organisation to perform a task.
- A Role is defined as collection of user with similar functions & responsibilities in the organisation.
- In RBAC the rights and permissions are granted to roles instead of individual users.
- RBAC is also known as Non-Discretionary access control.
- RBAC is basically a framework that provides the administrator with capabilities to regulate who can perform what action, when, from where, in what order and in some cases under what circumstances.

→ RBAC should be implemented in following situations :-

- ① In an effort to minimize downtime and accidental changes to cloud resource, the account to only a few people.

- ② In an effort to synchronize cloud product access to the function of an employee's job, the account owner would like to grant access to employees based on nature of their position.
- ③ In an effort to help prevent unauthorized access to cloud products through sharing of admin credentials, the account owner would like each user of cloud account to have their own credentials.